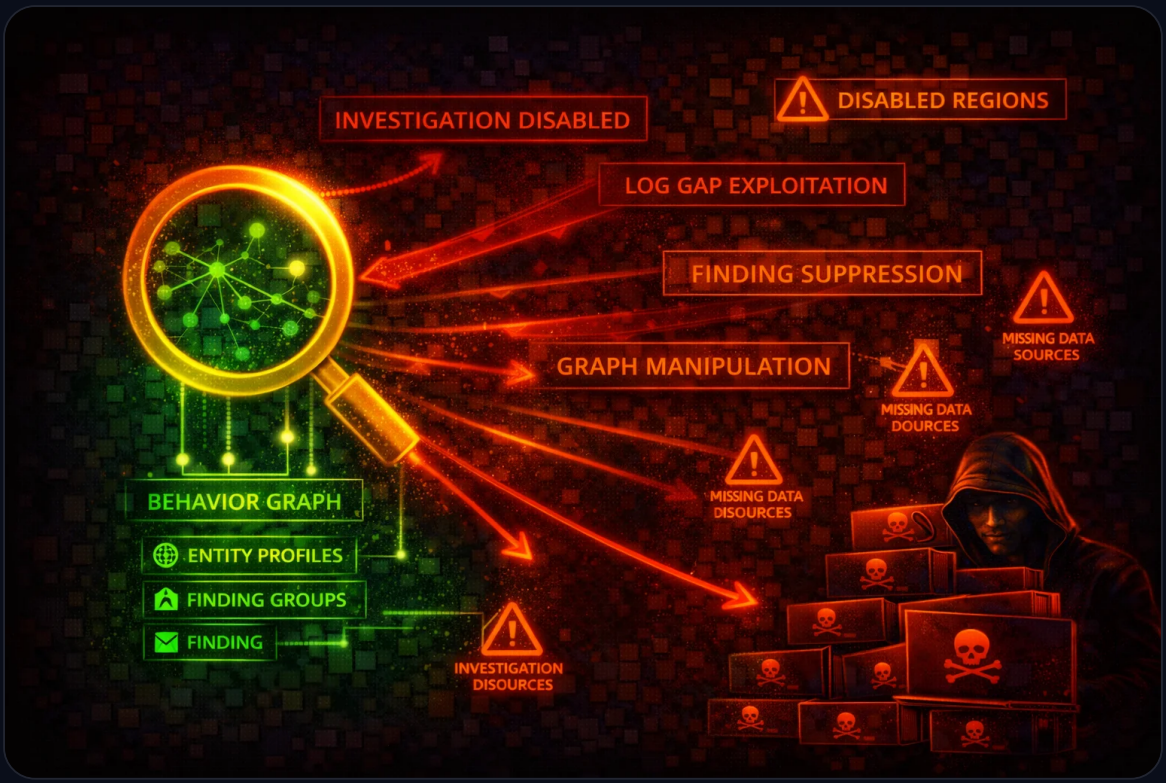

Amazon Detective Security

SECURITY INVESTIGATION

Amazon Detective automatically collects log data from AWS resources and uses machine learning, statistical analysis, and graph theory to build interactive visualizations for security investigations. Attackers target Detective to destroy forensic evidence and remove investigation capabilities.

ML + Graph	5	Up to 1 year	Per GB
Analysis	Data Sources	Data Retention	Pricing

📋 Service Overview

Behavior Graph

Detective builds a behavior graph from ingested data using ML and statistical analysis. The graph links entities (IP addresses, IAM principals, AWS accounts) with their activities over time.

Attack note: Deleting the behavior graph permanently destroys all correlated forensic data that cannot be recovered. Up to 1 year of investigation data is lost.

Multi-Account Architecture

An administrator account creates and manages the behavior graph, invites member accounts, and conducts investigations. Member accounts contribute data. Delegated administrator can auto-enable for all org accounts.

Attack note: Removing member accounts or disabling the delegated administrator breaks centralized security monitoring across the organization.

Security Risk Assessment

6.0

Risk Score

Detective is an investigation tool, not a detection tool. Disabling it does not stop alerts (GuardDuty still fires), but it destroys the forensic graph data needed to investigate incidents. Attackers who delete the behavior graph eliminate up to 1 year of correlated investigation data.

⚔️ Attack Vectors

Destroy Investigation Capability

- Delete behavior graph to destroy all forensic data
- Remove member accounts to stop data ingestion
- Disable Organizations delegated administrator
- Disassociate membership to remove from monitoring
- Reject invitations to prevent graph joining

Tamper with Investigations

- Update investigation state to close active investigations
- Delete members to stop data flow from specific accounts
- Update organization config to stop auto-enabling
- Tag resources with misleading metadata
- Operate from accounts not in the behavior graph

⚠️ Misconfigurations

Coverage Gaps

- Not all accounts enrolled in behavior graph
- Optional data packages not enabled (EKS, Security Hub)
- Delegated administrator not configured
- Auto-enable for new org accounts disabled
- Not enabled in all active regions

Operational Issues

- No EventBridge rules for Detective API changes
- No SCP preventing graph deletion
- Investigations not monitored for state changes
- Member accounts can disassociate themselves
- SearchGraph access not restricted

🔍 Enumeration

List All Behavior Graphs

```
aws detective list-graphs
```

List Member Accounts in a Graph

```
aws detective list-members \
  --graph-arn
arn:aws:detective:us-
east-1:111122223333:graph:
a1b2c3d4e5f6
```

List Datasource Packages

```
aws detective list-
datasource-packages \
  --graph-arn
arn:aws:detective:us-
east-1:111122223333:graph:
a1b2c3d4e5f6
```

List Investigations

```
aws detective list-
investigations \
  --graph-arn
arn:aws:detective:us-
east-1:111122223333:graph:
a1b2c3d4e5f6
```

List Organization Admin Accounts

```
aws detective list-
organization-admin-
accounts
```

📈 Privilege Escalation

Investigation Data Exposure

- detective:SearchGraph exposes cross-account activity data
- Administrator account sees all member account activity
- Investigation manipulation closes active investigations
- Cross-account visibility maps entire org security posture

Key insight: Detective itself does not directly enable privilege escalation. However, SearchGraph provides valuable reconnaissance for planning lateral movement across all member accounts.

🔗 Persistence

Reduce Forensic Visibility

- Remove specific member accounts (less obvious than graph deletion)
- Disable optional data source packages for blind spots
- Disassociate compromised accounts silently
- Time deletion to coincide with maintenance windows
- Operate within accounts not added to behavior graph

Operational Evasion

- Use unenrolled accounts as attack staging
- Operate during GuardDuty-to-Detective update interval
- Blend with normal traffic patterns in the graph
- Focus on services whose logs are not ingested
- Avoid triggering GuardDuty findings

🛡️ Detection

High-Severity Events

- DeleteGraph - behavior graph deleted
- DeleteMembers - members removed from graph
- DisableOrganizationAdminAccount - admin removed
- DisassociateMembership - account left graph

Medium-Severity Events

- UpdateDatasourcePackages - data source changed
- UpdateInvestigationState - investigation modified
- UpdateOrganizationConfiguration - org settings changed
- RejectInvitation - account declined invitation

💻 Exploitation Commands

Delete Behavior Graph (Destroys Forensic Data)

```
aws detective delete-graph \
  --graph-arn arn:aws:detective:us-
east-1:111122223333:graph:a1b2c3d4e5f6
```

Remove Member Accounts from Graph

```
aws detective delete-members \
  --graph-arn arn:aws:detective:us-
east-1:111122223333:graph:a1b2c3d4e5f6 \
  --account-ids 444455556666 777788889999
```

Disassociate Own Account from Graph

```
aws detective disassociate-membership \
  --graph-arn arn:aws:detective:us-
east-1:111122223333:graph:a1b2c3d4e5f6
```

Disable Organization Admin Account

```
aws detective disable-organization-admin-account
```

Close an Active Investigation

```
aws detective update-investigation-state \
  --graph-arn arn:aws:detective:us-
east-1:111122223333:graph:a1b2c3d4e5f6 \
  --investigation-id 12345678901234567890 1 \
  --state ARCHIVED
```

📜 Policy Examples

✗ Dangerous - Full Detective Access

```
{
  "Effect": "Allow",
  "Action": "detective:*",
  "Resource": "*"
}
```

Full access allows deleting behavior graphs, removing members, and destroying all forensic data

✓ Secure - Read-Only Analyst

```
{
  "Effect": "Allow",
  "Action": [
    "detective:Get*",
    "detective:List*",
    "detective:BatchGet*",
    "detective:SearchGraph"
  ],
  "Resource": "*"
}
```

Read-only access for security analysts to investigate findings without modification rights

✓ **Secure - SCP Prevent Tampering**

```
{
  "Effect": "Deny",
  "Action": [
    "detective:DeleteGraph",
    "detective:DeleteMembers",
    "detective:DisableOrganizationAdminAccount",
    "detective:DisassociateMembership"
  ],
  "Resource": "*"
}
```

Prevents deleting behavior graphs or removing member accounts at the organization level

🛡️ Defense Recommendations

🏢 Use Organization Delegated Administrator

Centralize Detective management so member accounts cannot disable it or leave the behavior graph.

```
aws detective enable-organization-admin-account \
  --account-id 123456789012
```

🔒 SCP to Prevent Graph Deletion

Use Service Control Policies to deny Detective destructive actions across all member accounts.

🌍 Enable in All Regions

Detective must be enabled per-region. Ensure behavior graphs exist in every active region.

🔔 Alert on Detective Changes

Create EventBridge rules to alert on destructive Detective API calls via CloudTrail.

```
aws events put-rule --name "DetectiveTamperingAlert" \
  --event-pattern '{"source":["aws.detective"],"detail":
{"eventName":["DeleteGraph","DeleteMembers"]}}'
```

📊 Auto-Enable for New Accounts

Ensure new accounts are automatically added to the behavior graph.

```
aws detective update-organization-configuration \
  --graph-arn GRAPH_ARN --auto-enable
```

Enable All Data Source Packages

Enable optional data source packages for maximum investigation coverage (EKS, Security Hub).

```
aws detective update-datasource-packages \
  --graph-arn GRAPH_ARN \
  --datasource-packages EKS_AUDIT
ASFF_SECURITYHUB_FINDING
```


Always obtain proper authorization before testing